

APUNTESWEB · INGENIERÍA INFORMÁTICA

SEGINFO

Tercer curso · 2.º cuatrimestre · 5 temas

JULIO DE 2026 · [HTTPS://ADRIANQL5.GITHUB.IO/APUNTESWEB/](https://adrianql5.github.io/apuntesweb/)

1. Protección de la Privacidad en el Mundo Digital

1.1 Privacidad y recogida de datos

Privacidad: derecho a controlar qué conocen otros sobre nosotros, nuestras comunicaciones y nuestra actividad. No afecta solo a nombre o DNI: también incluye hábitos, conducta, ubicación, salud, datos biométricos, finanzas o cualquier **dato sensible según el contexto**.

- **Sujeto:** persona o entidad descrita por los datos.
- **Propietario:** quien posee los datos.
- Problema actual: recogida masiva, consentimientos poco claros y pérdida de control una vez entregados los datos.

Una recogida correcta debe ser legal, clara, proporcional a la finalidad, precisa y actualizada. También debe informar de finalidad y conservación, pedir consentimiento o base legal para nuevos usos, proteger contra pérdida o uso indebido, permitir acceso/rectificación/reclamación y tener un responsable o controlador.

1.2 Exposición y huella digital

En Internet se suelen pedir más datos de los necesarios. Antes de rellenar formularios conviene valorar el servicio, la publicidad/seguimiento asociado y la política de privacidad.

Fuentes típicas de exposición: listas públicas, boletines, resoluciones, blogs, firmas en manifiestos, asociaciones, sindicatos, peticiones y redes sociales. **Egosurfing** = buscar información propia en Internet para controlar la identidad digital.

Comportamiento digital: toda actividad con dispositivos digitales deja rastro. Ordenadores, móviles, cuentas de grandes proveedores y wearables pueden registrar archivos, descargas, llamadas, tiempo de uso, salud o ubicación. Preguntas clave: cómo se transmiten los datos, dónde se almacenan, quién accede y si se comparten con terceros.

1.3 Técnicas de seguimiento

- **Cookies:** almacenan datos en el equipo y los recuperan al volver a una web. Tipos: propias/de terceros, de sesión/persistentes, técnicas/personalización/publicidad comportamental/análisis. Las de terceros y publicidad comportamental son las más invasivas.

- **Web bugs o web beacons:** elementos invisibles en webs o correos que registran IP, navegador, sistema, fecha u hora. Se reducen bloqueando imágenes automáticas y usando bloqueadores.
- **Spyware:** código que espía y recopila datos; los **hijackers** alteran programas para redirigir o exfiltrar información.
- **Logs:** registros de servidores o sistemas, por ejemplo IP, fecha, recurso accedido, navegador y página de procedencia. También permiten perfilar comportamiento.

1.4 Reducir rastros y ganar anonimato

Medidas básicas: evitar autocompletado con datos sensibles, limitar cookies, borrar caché e historial, no iniciar sesión en el navegador si no hace falta, cerrar sesiones y separar navegadores por uso.

La navegación privada solo reduce rastros locales; los servidores siguen registrando actividad.

Para más anonimato: equipos públicos, proxies, cuentas anónimas y redes como **Tor**, **I2P** o **Hyphernet/Freenet**. Aun así, anonimato local o frente a una web no equivale a anonimato total.

1.5 Redes sociales y tecnologías

En redes sociales: perfil privado si hay duda, verificar desconocidos, no publicar datos de terceros, pensar en la reputación futura y no compartir información no verificada.

- **RFID:** identificador único; facilita seguimiento de objetos/personas e inferencias personales.
- **Nube:** la ubicación física y jurídica de los datos afecta a privacidad, confidencialidad y jurisdicción.
- **Voto electrónico:** debe proteger el secreto del voto y evitar saber si alguien votó o a quién votó.

Para test

- Privacidad = control sobre información personal y comportamiento.
- Los datos sensibles dependen del contexto.
- Privacidad suele costar comodidad, personalización o calidad de servicio.
- Técnicas clave de rastreo: cookies, web bugs, spyware y logs.
- Cookies de terceros/publicidad comportamental = más problemáticas.
- Navegación privada no oculta la actividad al servidor.
- Recursos: **AEPD**, **INCIBE** y **EPIC**.

2. SGSI Análisis y gestión de riesgos

2.1 Información, activos y SGSI

Información: conjunto de datos organizados con valor para una entidad, sin importar formato, origen o fecha. Es un activo crítico durante todo su ciclo de vida: creación, almacenamiento, proceso, transmisión, uso, corrupción, robo, pérdida o destrucción.

Seguridad de la información según ISO/IEC 27001: preservar **confidencialidad, integridad y disponibilidad (CIA)**. También pueden añadirse autenticidad, responsabilidad, no repudio y confiabilidad.

Clasificación típica de la información:

- **Pública/open:** puede difundirse sin daño relevante.
- **Interna/propietaria:** su divulgación no autorizada sería inconveniente.
- **Confidencial/restringida:** sensible o valiosa; requiere autorización expresa.

Un **SGSI** es un sistema formal, documentado, conocido por la organización, basado en riesgos y orientado a mejora continua. Busca proteger eficientemente y mantener el riesgo por debajo del nivel asumible.

2.2 Ciclo PDCA del SGSI

- **Plan:** definir política, metodología de riesgo, identificar/evaluar riesgos, elegir tratamiento y controles, elaborar **SoA**, aprobar riesgos residuales y autorizar el SGSI.
- **Do:** implantar tratamiento y controles, formar al personal, gestionar operaciones/recursos y preparar detección/respuesta ante incidentes.
- **Check:** revisar SGSI, medir controles, revisar riesgos residuales, registrar eventos y hacer auditorías internas.
- **Act:** aplicar mejoras, acciones correctivas/preventivas, comunicar resultados y comprobar eficacia.

2.3 Análisis de riesgos

El análisis empieza identificando **activos:** todo lo que tiene valor y debe protegerse. Ejemplos: datos, contratos, documentación, software, equipos, comunicaciones, servicios, suministros, personas, tiempo de recuperación e imagen.

Conceptos básicos:

- **Amenaza:** evento que puede dañar un activo.
- **Vulnerabilidad:** debilidad que puede explotar una amenaza.
- **Impacto:** daño producido.
- **Riesgo:** impacto ponderado por la probabilidad.

Relación clave: las amenazas explotan vulnerabilidades, afectan a activos y los controles reducen el riesgo.

Amenazas típicas: empleados, temporales, consultores, competidores, atacantes, errores, desastres naturales, malware, robo, sabotaje, fallos de red/sistema, incendios, falta de documentación o seguridad física débil.

2.4 Valoración y tratamiento

Los activos se valoran con la tríada **CIA**. El impacto puede ser:

- **Coste inmediato:** recuperar la operación en los días siguientes.
- **Coste a largo plazo:** pérdida de imagen, confianza o clientes.

Escala de probabilidad vista en clase:

- **1**: nunca.
- **2**: raro, aprox. una vez al año.
- **3**: periódico, aprox. una vez por trimestre.
- **4**: regular, aprox. una vez cada 15 días.
- **5**: frecuente, aprox. una vez por semana.

Fórmula simplificada: $\text{Riesgo} = \text{impacto o severidad} \times \text{probabilidad}$.

Tratamiento del riesgo:

- **Asumirlo:** aceptarlo.
- **Eliminarlo:** quitar la causa o actividad.
- **Mitigarlo:** reducirlo con controles.
- **Transferirlo:** pasarlo a terceros, por ejemplo seguros.

Los riesgos aceptables se asumen, los tolerables requieren seguimiento y los no aceptables deben tratarse. Mitigar compensa si el coste del control es menor que la pérdida esperada. La dirección acepta el riesgo residual.

2.5 Dirección y plan director

La dirección aprueba riesgos residuales, autoriza la implantación del SGSI y formaliza el compromiso de ejecutar acciones.

Plan director de seguridad: diagnóstico, análisis de riesgos, verificación de cumplimiento (por ejemplo ISO 27001), proyectos a corto/medio/largo plazo y gestión de riesgos. **MAGERIT v3** es referencia importante en la administración electrónica española.

Para test

- Información = activo esencial.
- SGSI = sistema documentado, basado en riesgos y mejora continua.
- Seguridad de la información = CIA.
- Riesgo = impacto x probabilidad.
- Riesgo se puede asumir, eliminar, mitigar o transferir.
- La dirección aprueba riesgos residuales e implantación.

3. Políticas de seguridad y estándares

3.1 Enfoque general

La seguridad de la información es un **proceso**, no un producto. Requiere políticas, procedimientos, medidas técnicas, gestión de incidentes y auditorías.

Metas clásicas:

- **Prevención:** evitar que se viole la política.
- **Detección:** descubrir que se ha violado.
- **Recuperación:** detener el ataque, reparar daños y seguir funcionando.

Diferencia clave: la **política** dice qué está permitido; los **mecanismos o controles** dicen cómo se hace cumplir. En entornos militares/gubernamentales suele pesar más la confidencialidad; en comerciales, integridad y disponibilidad.

3.2 Políticas y controles

Ejemplos de políticas:

- **Contraseñas:** generación automatizada, mínimo 10 caracteres, mayúsculas, minúsculas, números, caracteres especiales y cambio periódico.
- **Software:** no instalar programas sin autorización.

Los controles aplican la política y pueden ser técnicos, físicos u organizativos. Ejemplos: autenticación biométrica, restricción de dispositivos externos y procedimientos de instalación, copia o acceso.

INCIBE sirve como referencia práctica de modelos de políticas y planes directores.

3.3 Estándares

Los estándares aportan interoperabilidad, uniformidad, certificación y orden. No hay un estándar perfecto para todo: depende del servicio, tamaño y facilidad de implantación.

Ejemplos importantes:

- **Orange Book:** criterios del Departamento de Defensa de EE. UU.
- **BS 7799:** antecedente histórico de gestión de seguridad.
- **COBIT:** gobierno, auditoría y control de TI, creado por ISACA.
- **ISO/IEC 27000:** familia de normas de seguridad de la información.

- **ENS**: marco español para administraciones y entidades sujetas a él; regulado por el **Real Decreto 311/2022, de 3 de mayo**.

3.4 ISO/IEC 27001 y 27002

La familia **ISO/IEC 27000** se aplica a organizaciones públicas o privadas, grandes o pequeñas.

- **ISO/IEC 27001**: norma principal y única certificable. Define requisitos para establecer, implementar, operar, monitorizar, revisar, mantener y mejorar un **SGSI**. Usa ciclo **PDCA**.
- **ISO/IEC 27002**: guía de buenas prácticas y controles. En clase: **114 controles, 35 objetivos de control y 14 dominios**.
- Otras: **27003** implementación, **27004** métricas, **27005** riesgos, **27006** acreditación, **27010** información compartida, **27034** aplicaciones y **27799** ámbito sanitario.

Dominios de 27002: políticas, organización, recursos humanos, activos, accesos, cifrado, seguridad física, operaciones, telecomunicaciones, adquisición/desarrollo/mantenimiento, proveedores, incidentes, continuidad de negocio y cumplimiento.

3.5 Ejemplo y test

Ejemplo público: plan director de seguridad TIC de la Xunta de Galicia, con cinco dimensiones: formación y concienciación, cumplimiento normativo, marco organizativo, marco operacional y medidas de protección.

Para examen:

- Seguridad = prevención + detección + recuperación.
- Política = qué se permite; control = cómo se cumple.
- Los estándares ayudan a implantar, ordenar, auditar y certificar.
- **ISO/IEC 27001** = SGSI y certificable.
- **ISO/IEC 27002** = controles de buenas prácticas.
- **ENS** = referencia principal del sector público español.

4. Fundamentos jurídicos básicos

4.1 Conceptos generales

- **Derecho objetivo:** conjunto de normas que rigen la sociedad para evitar conflictos.
- **Derecho subjetivo:** facultad que una norma concede a una persona para hacer, no hacer o exigir algo.
- **Derechos fundamentales:** libertades y facultades esenciales ligadas a la dignidad humana. Si están en la CE, se sitúan en la Sección 1.^a del Capítulo II del Título I.
- **Constitución Española (CE):** se organiza en títulos, capítulos y secciones.
- **Ordenamiento jurídico (OJ):** conjunto de normas/derechos objetivos.
- El **derecho a la vida** se considera el más importante.

4.2 Estado social y democrático de Derecho

El **art. 1.1 CE** define España como **Estado social y democrático de Derecho**.

Estado democrático

Los ciudadanos participan en la política mediante elecciones. Implica:

- Soberanía popular.
- Elecciones libres y periódicas.
- Pluralismo político.
- Participación en asuntos públicos.

Estado social

Busca que la igualdad formal se convierta en **igualdad material**: dar apoyo a quien lo necesita.

- **Art. 9.2 CE:** los poderes públicos deben promover libertad e igualdad reales y efectivas.
- **Principios rectores:** aparecen en el Capítulo III del Título I. No son plenamente exigibles por sí solos salvo desarrollo legal.
- **Art. 53.3 CE:** vinculan a legislación, práctica judicial y actuación de los poderes públicos; no se debe actuar contra ellos.

Estado de Derecho

Los poderes públicos están sometidos a la ley. Se basa en:

- Separación de poderes.
- Sometimiento al imperio de la ley.
- Reconocimiento y garantía de los derechos fundamentales.

Art. 9.1 CE: ciudadanos y poderes públicos están sujetos a la CE y al resto del OJ.

Art. 9.3 CE: garantiza:

- **Legalidad:** la Administración y las sanciones deben ajustarse al Derecho.
- **Jerarquía normativa:** CE > leyes > reglamentos.
- **Publicidad de normas:** publicación en BOE; regla general de entrada en vigor a los **20 días** si no se dice otra cosa.
- **Irretroactividad desfavorable:** no se aplican hacia atrás normas sancionadoras o restrictivas perjudiciales; lo favorable sí puede ser retroactivo.
- **Seguridad jurídica:** certeza y previsibilidad.
- **Responsabilidad de los poderes públicos.**
- **Interdicción de la arbitrariedad:** prohibición de actuar caprichosamente.

4.3 Separación de poderes

Separación horizontal:

- **Legislativo:** elabora y aprueba leyes. Cortes Generales: Congreso y Senado.
- **Ejecutivo:** gobierna y administra.
- **Judicial:** aplica las leyes y juzga.

Separación vertical:

- Estado.
- Comunidades autónomas.
- Entidades locales.

Conceptos:

- **Poder constituyente:** poder originario del pueblo para crear o reformar una Constitución.
- **Poder constituido:** poderes creados por la Constitución y sometidos a ella.

4.4 Fuentes del Derecho

Según el **art. 1 del Código Civil**, las fuentes son:

1. **Ley.**
2. **Costumbre.**
3. **Principios generales del Derecho.**

Ley

Norma escrita. Pirámide básica: **Constitución > leyes > reglamentos**. Entre normas del mismo rango, la posterior deroga a la anterior.

- **Constitución**: norma suprema del OJ.
- **Ley orgánica**: aprobada por el poder legislativo con **mayoría absoluta**. Regula derechos fundamentales, Estatutos de Autonomía y régimen electoral general.
- **Ley ordinaria**: aprobada por **mayoría simple**. Regula materias no reservadas a ley orgánica.

Importante: ley orgánica y ley ordinaria no se diferencian por jerarquía, sino por materia y mayoría.

Normas con rango de ley

Las aprueba el poder ejecutivo, pero tienen rango de ley.

- **Decreto-ley**: extraordinaria y urgente necesidad. Entra en vigor de inmediato, pero debe convalidarse o rechazarse en **30 días**.
- **Decreto legislativo**: el ejecutivo legisla por delegación del legislativo.
 - **Ley de bases** -> **texto articulado**.
 - **Ley ordinaria** -> **texto refundido**.

Reglamentos

Normas del poder ejecutivo inferiores a la ley. Desarrollan o ejecutan leyes.

- **Real Decreto** estatal / **Decreto** autonómico.
- **Orden ministerial** estatal / **Orden** autonómica.
- **Ordenanza** municipal.

4.5 Costumbre y principios generales

La **costumbre** es norma jurídica no escrita. Debe ser:

- Uniforme.
- Continuada.
- Generalizada.
- Considerada jurídicamente obligatoria.

Se aplica en defecto de ley y no puede ir contra la ley ni el orden público.

Los **principios generales del Derecho** son ideas básicas de justicia y lógica. Se aplican en defecto de ley y costumbre y sirven para interpretar el OJ.

4.6 Derecho de la Unión Europea

El Derecho de la UE es un ordenamiento propio. No compete por jerarquía con el Derecho interno, sino por **principio de competencia** ligado al **art. 93 CE**.

- **Reglamento:** eficacia directa; obligatorio sin transposición.
- **Directiva:** obliga al resultado; necesita transposición al Derecho interno. Si no se transpone a tiempo, puede haber sanciones.

4.7 Potestad de la Administración Pública

Potestad: poder jurídico atribuido normalmente a la Administración para actuar en defensa del interés general, incluso imponiendo decisiones unilaterales y obligatorias.

Tipos:

- **Reglada:** la ley fija todos los elementos; la Administración solo verifica hechos.
- **Discrecional:** la ley deja margen para elegir entre opciones válidas.

Para test

- Derecho objetivo = norma; derecho subjetivo = facultad.
- Art. 1.1 CE = Estado social, democrático y de Derecho.
- Art. 9.1 CE = sometimiento a CE y OJ.
- Art. 9.3 CE = legalidad, jerarquía, publicidad, irretroactividad desfavorable, seguridad jurídica, responsabilidad y no arbitrariedad.
- Fuentes: ley, costumbre y principios generales.
- Jerarquía: CE > leyes > reglamentos.
- Reglamento UE = directo; directiva = transposición.
- Potestad reglada = sin margen; discrecional = con margen legal.

5. Protección de datos RGPD y LOPDGDD

5.1 Protección de datos

La **protección de datos** es un derecho fundamental reconocido a nivel nacional y europeo.

Norma principal: **Reglamento (UE) 2016/679, RGPD**, de aplicación directa.

Objetivos del RGPD:

1. Garantizar la libre circulación de datos personales.
2. Regular el derecho de las personas físicas a proteger sus datos.

5.2 Conceptos básicos

- **Dato personal:** información sobre una persona física identificada o identificable.
- **Identificable:** puede saberse quién es directa o indirectamente mediante nombre, DNI, IP, rasgos físicos, genéticos, etc.
- **Interesado/titular:** persona física a la que pertenecen los datos.
- **Tratamiento:** cualquier operación sobre datos personales, automatizada o no.
- **AEPD:** autoridad de control en España.

Capacidades:

- **Capacidad jurídica:** ser titular de derechos y obligaciones. Se adquiere al nacer, es universal y no se pierde.
- **Capacidad de obrar:** ejercer derechos válidamente por uno mismo. Depende de edad y condiciones personales.

5.3 Ámbitos de aplicación del RGPD

Subjetivo

- Titulares de derechos: **personas físicas**.
- Titulares de obligaciones: personas físicas o jurídicas, públicas o privadas.
- Personas fallecidas: el RGPD no se aplica directamente. En España, familiares/herederos pueden pedir rectificación o supresión salvo prohibición expresa del fallecido.

Territorial

Se aplica si:

- El tratamiento se realiza en la UE.
- Se ofrecen bienes o servicios a personas en la UE.
- Se monitoriza el comportamiento de personas en la UE.

Material

Se aplica a:

- Tratamientos automatizados.
- Tratamientos manuales si los datos están o estarán en un fichero organizado.

Quedan fuera:

- Seguridad nacional y materias fuera del ámbito UE.
- Política Exterior y de Seguridad Común.
- Investigación, detección o enjuiciamiento penal.
- Actividades personales o domésticas.

En redes sociales puede no haber excepción doméstica si los datos son accesibles a mucha gente, indexables por buscadores, afectan a terceros o son sensibles.

5.4 Consentimiento y menores

Consentimiento: manifestación libre, específica, informada e inequívoca mediante acción afirmativa. No vale el consentimiento tácito.

Condiciones destacadas:

- Debe poder retirarse tan fácilmente como se dio.
- La información debe ser clara, sencilla e inteligible.
- RGPD: menores pueden consentir desde los **16 años**, con posibilidad estatal de bajarlo hasta 13.
- España: la LOPDGDD lo fija en **14 años**.

5.5 Categorías especiales de datos

Su tratamiento está prohibido salvo excepciones suficientes, como consentimiento explícito u obligación legal.

Incluyen:

- Datos biométricos.

- Datos de salud.
- Datos genéticos.
- Orientación sexual.
- Raza/origen.
- Otros datos especialmente sensibles.

5.6 Roles en el tratamiento

- **Responsable:** determina fines y medios del tratamiento.
- **Encargado:** trata datos por cuenta del responsable.
- **Delegado de Protección de Datos (DPD):** asesora, supervisa cumplimiento y actúa como punto de contacto con interesados y autoridad de control.

Responsable y encargado deben aplicar medidas técnicas y organizativas adecuadas y valorar evaluación de impacto o consulta previa cuando proceda.

5.7 Principios del art. 5 RGPD

- **Licitud, lealtad y transparencia:** base legal y explicación clara.
- **Limitación de finalidad:** fines explícitos y legítimos.
- **Minimización:** solo datos adecuados, pertinentes y necesarios.
- **Exactitud:** datos correctos; si no, rectificación o supresión.
- **Limitación de conservación:** conservar solo el tiempo necesario; después suprimir o anonimizar.
- **Integridad y confidencialidad:** impedir accesos no autorizados.
- **Responsabilidad proactiva:** cumplir y poder demostrarlo.

5.8 Licitud del tratamiento: art. 6 RGPD

El tratamiento es lícito si existe al menos una base:

1. Consentimiento.
2. Ejecución de contrato.
3. Obligación legal.
4. Intereses vitales.
5. Interés público o ejercicio de poderes públicos.
6. Interés legítimo del responsable o tercero, salvo que prevalezcan derechos del interesado.

En Administraciones Públicas, el **interés legítimo** no se aplica cuando actúan en ejercicio de sus funciones. Según el **art. 8 LOPDGDD**, interés público o poderes públicos deben derivar de una competencia atribuida por norma con rango de ley.

5.9 Autoridades de protección de datos

El RGPD exige autoridades de control independientes.

En España:

- **AEPD.**
- **APDCAT.**
- **AVPD.**
- Consejo de Transparencia y Protección de Datos de Andalucía.

Las autoridades autonómicas pueden actuar sobre tratamientos del sector público autonómico/local, funciones públicas autonómicas/locales y tratamientos previstos en Estatutos.

Garantías de independencia:

- Autoridad administrativa independiente.
- Presidencia mediante convocatoria pública y control parlamentario.
- Presupuesto propio.
- Recursos suficientes.
- Sin instrucciones externas.

Competencias:

- **Investigación:** pedir información, auditar, acceder a datos/locales y revisar certificaciones.
- **Correctoras:** advertencias, órdenes, limitación/prohibición de tratamientos, suspensión de flujos, retirada de certificaciones, amonestaciones y multas.
- **Asesoramiento:** consulta previa, dictámenes, códigos de conducta y certificación.

Multas RGPD:

- Hasta **10 millones o 2 %** del volumen global anual.
- Hasta **20 millones o 4 %** del volumen global anual para infracciones más graves.

5.10 Servicios públicos proactivos

Servicios proactivos: la Administración se anticipa y ofrece servicios ya cumplimentados usando información que ya tiene del ciudadano.

Ventaja: evita que personas vulnerables pierdan ayudas por desconocimiento.

Riesgo: puede excluir a quien tiene menos competencias digitales o de quien hay menos datos.

Idea clave: la protección de datos busca proteger derechos fundamentales, no bloquear por sistema el uso de datos.

Ejemplos:

- **Asturias:** habilita tratamiento de datos en historia social única para gestión de servicios sociales y protección de colectivos vulnerables.
- **Cataluña:** la APDCAT ha sido más restrictiva y exige consentimiento explícito en iniciativas de servicios proactivos.
- **STS 1206/2025:** permite a la Agencia Tributaria usar datos de terceros sin consentimiento para investigar fraude fiscal por obligación legal e interés público.

5.11 Derechos del interesado

Derechos principales:

- **Información:** arts. 13 y 14 RGPD.
- **Acceso:** saber si se tratan datos y obtener copia.
- **Rectificación:** corregir datos inexactos o incompletos.
- **Supresión/derecho al olvido:** eliminar datos si concurre causa legal.
- **Limitación:** restringir temporalmente el tratamiento.
- **Portabilidad:** recibir datos en formato estructurado y transmitirlos a otro responsable.
- **Oposición:** oponerse por interés público, poderes públicos o interés legítimo; siempre cabe ante marketing directo.
- **No decisiones automatizadas:** no sufrir decisiones solo automatizadas con efectos jurídicos o significativos.

Información cuando se recogen datos del interesado

Debe informarse de responsable, DPD, fines, base jurídica, destinatarios, transferencias internacionales, plazo de conservación, derechos, retirada del consentimiento, reclamación ante autoridad, obligación de facilitar datos y decisiones automatizadas.

Información si los datos no se obtienen del interesado

Además de lo anterior, deben indicarse categorías de datos y fuente de procedencia.

Excepciones: información imposible o desproporcionada, obligación legal con garantías o secreto profesional.

Aplicación en España: art. 11 LOPDGDD

Información básica directa:

- Identidad del responsable.
- Finalidad.
- Posibilidad de ejercer derechos de los arts. 15 a 22 RGPD.
- Si no vienen del interesado: categorías y fuente.

El resto puede facilitarse mediante dirección electrónica u otro medio sencillo.

5.12 Matices de derechos

- **Acceso:** puede pedirse concreción si hay muchos datos. Si es infundado o repetitivo, puede denegarse. Más de una solicitud en seis meses se presume repetitiva salvo causa legítima.
- **Supresión:** procede si los datos ya no son necesarios, se retira consentimiento, hay oposición, tratamiento ilícito, obligación legal o datos de menores en servicios de sociedad de la información.
- **Supresión no procede** si el tratamiento es necesario para libertad de expresión/información, obligación legal, interés público, salud pública, archivo/investigación/estadística o reclamaciones.
- **Limitación:** por impugnación de exactitud, tratamiento ilícito, necesidad para reclamaciones u oposición pendiente.
- **Portabilidad:** exige tratamiento basado en consentimiento y por medios automatizados. No se aplica a misión de interés público o poderes públicos.
- **Decisiones automatizadas:** excepciones por contrato, norma con garantías o consentimiento explícito. En contrato/consentimiento hay derecho a intervención humana, expresar opinión e impugnar.

Las normas pueden limitar derechos si es necesario y proporcionado para salvaguardar intereses públicos superiores.

5.13 Delegado de Protección de Datos

Designación obligatoria si:

- Tratamiento por sector público, salvo tribunales en función judicial.
- Observación habitual y sistemática a gran escala.
- Categorías especiales a gran escala.
- Datos de condenas e infracciones penales.

En España también aparece en muchos sectores: colegios profesionales, centros docentes, universidades, telecomunicaciones, crédito, aseguradoras, sanidad, seguridad privada, juego online y federaciones deportivas.

Posición:

- No recibe instrucciones.
- No puede ser sancionado o destituido por sus funciones, salvo negligencia grave o dolo.
- Rinde cuentas al máximo nivel jerárquico.
- Debe tener recursos, secreto profesional y ausencia de conflicto de intereses.

Funciones:

- Informar y asesorar.

- Supervisar cumplimiento.
- Asesorar sobre evaluaciones de impacto.
- Cooperar con autoridades de control.
- Ser punto de contacto.
- Comunicar fallos a órganos de dirección.

5.14 Reglamento de Inteligencia Artificial de la UE

Reglamento (UE) 2024/1689, de 13 de junio de 2024. Publicado el 12 de julio de 2024, en vigor desde el 2 de agosto de 2024 y aplicable con carácter general desde el 2 de agosto de 2026.

Enfoque: regulación general basada en riesgos, con códigos de conducta para sistemas que no sean de alto riesgo. Se usa reglamento para evitar fragmentación jurídica.

Sistema de IA: sistema basado en máquina, con autonomía variable, que genera predicciones, contenidos, recomendaciones o decisiones que influyen en entornos físicos o virtuales.

Prácticas prohibidas:

- Técnicas subliminales, manipuladoras o engañosas con perjuicios.
- Explotación de vulnerabilidades por edad, discapacidad o situación social/económica.
- Puntuación social injustificada o desproporcionada.
- Predicción penal basada solo en perfiles o rasgos personales.
- Bases de reconocimiento facial por extracción masiva no selectiva.
- Inferencia de emociones en trabajo o educación, salvo motivos médicos o seguridad.
- Categorización biométrica para inferir raza, opiniones, vida u orientación sexual.
- Identificación biométrica remota en tiempo real en espacios públicos, salvo excepciones graves.

Sistemas de alto riesgo:

- Componentes de seguridad o productos sujetos a evaluación ex ante.
- Sistemas con impacto en derechos fundamentales.
- Requisitos: gestión de riesgos, gobernanza de datos, registros, transparencia, supervisión humana, precisión, solidez y ciberseguridad.

Sistemas no de alto riesgo: obligaciones de transparencia si interactúan con personas, generan contenido sintético o hacen reconocimiento de emociones/categorización biométrica.

Modelos de IA de uso general: modelos con gran generalidad y muchas tareas. Los de **riesgo sistémico** tienen capacidades de gran impacto y deben notificarse a la Comisión.

5.15 IA en Galicia

Ley 2/2025, de 2 de abril, para el desarrollo e impulso de la IA en Galicia.

Finalidad:

- Regular el uso de IA en el sector público gallego.
- Impulsar IA en empresa, investigación e innovación.

Principios:

- Fiabilidad e imparcialidad.
- Comisionados de IA.
- Explicabilidad e interpretabilidad.
- Seguridad y privacidad.
- Universalidad y accesibilidad.
- Proactividad y personalización.
- Reserva de humanidad y revisión humana.
- Precaución y responsabilidad.
- Transparencia y claridad.

Organización:

- Órganos promotores funcionales y responsables tecnológicos.
- Oficina de IA.
- Comisión estratégica para asesoramiento en IA.
- Consejo Gallego de IA.

Planificación:

- Estrategia gallega de IA.
- Programas sectoriales de IA.
- Proyectos de IA.

Medidas de impulso:

- Estratégicas: mapa del ecosistema IA e incorporación a política industrial.
- Técnicas: infraestructuras y simplificación administrativa.
- Económicas: inversión directa/indirecta y beneficios fiscales.
- Capital humano: formación, capacitación y atracción de talento.

Para test

- RGPD = Reglamento UE 2016/679, aplicación directa.
- Dato personal = persona física identificada o identificable.
- Menores en España: consentimiento desde 14 años.
- Bases art. 6: consentimiento, contrato, obligación legal, intereses vitales, interés público/poderes públicos e interés legítimo.
- Principios art. 5: licitud, finalidad, minimización, exactitud, conservación, integridad/confidencialidad y responsabilidad proactiva.

- Responsable decide fines/medios; encargado actúa por cuenta del responsable; DPD asesora y supervisa.
- Derechos: información, acceso, rectificación, supresión, limitación, portabilidad, oposición y no decisiones automatizadas.
- Autoridades: AEPD y autonómicas; competencias de investigación, corrección y asesoramiento.
- Reglamento IA UE = enfoque por riesgos; alto riesgo exige controles fuertes; algunas prácticas están prohibidas.